

Cybersecurity risk is an inherent part of cybersecurity practice. It defines the essential elements needed to secure technical infrastructure, tangible and intangible assets, technology in use, and the reputation of the organization in case of a cyberattack or data breach. It also defines the objectives of an organization to protect itself from data theft that can cause potential damage. It is important from the perspective of security professionals to compute the cybersecurity risk of an organization so that appropriate measures can be taken in advance to prevent cyber risks.

This chapter delves deep into the basic principles of cybersecurity, motivation to breach cybersecurity, the CIAAA principle, the importance of data science in cybersecurity, and a list of important data breaches. We begin with a simple definition of cybersecurity and continue toward the basic building blocks of cybersecurity throughout this chapter.

2.1 What Is Cybersecurity?

Cybersecurity refers to designing, developing, and using technologies, processes, and practices to protect organizational assets, customer data, and intellectual property from intentional or unintentional breaches by unauthorized personnel. The unauthorized personnel are also called cybercriminals. However, it is untrue that only unauthorized personnel can be involved in the violation of sensitive data. There are several examples of the involvement of authorized persons who breached the code of conduct and stole critical organization data for misuse.

Simply put, cybersecurity is the collection of technologies, processes, and practices that aim to protect an organizational asset from unauthorized access or authorized misuse. Unauthorized personnel can be classified as hackers, nation-state activists, and script kiddies, while authorized personnel who misuse their assigned privileges are called malicious insiders. We will explore all these terms in the later chapters.

Every organization has its unique needs, assets, resources, and sensitive data. Therefore, cybersecurity planning to protect these entities is also different for every organization. However, to mitigate cyberattacks and protect sensitive data and assets, it is desired that every organization plans for a cybersecurity policy that drafts the risk appetite of the organization. The risk appetite ensures the amount of risk that the organization can accept without any negative impact on its business.

2.2 Motivation

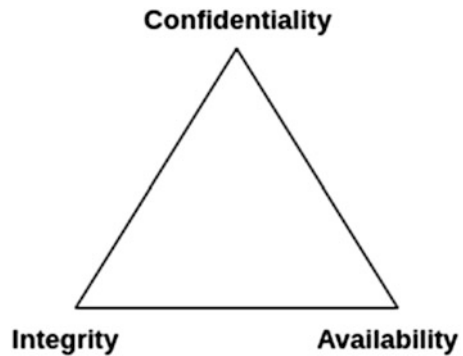
Widespread use of computers and networks in all sectors such as communication, finance, transportation, education, military, and government, has become a source of attraction for cybercriminals to target these sectors for financial gain. Some of the important motivations behind cyberattacks are listed below:

- **Data breach:** According to the analysis of major cyberattacks between 2001 and 2013 (Vaidya 2015), the primary motivation behind launching a cyberattack is to steal sensitive data and cyber espionage.
- **Financial instability:** Cyber risk is potentially cited as the top priority for all types of organizations, especially financial systems. Cyberattacks pose a substantial risk to the financial stability of the overall financial sector (Boer and Vazquez 2017).
- **Service disruption:** Apart from financial instability, cyberattacks can disrupt business and financial markets as well. During the WannaCry ransomware outbreak in 2017, over 200,000 computers were affected in around 150 countries. It disrupted essential services including hospitals, telecommunications, railways, and automobile companies.
- **Political:** Cyberattacks are also politically motivated at times. Stuxnet is the popular example of a malware attack on Iranian nuclear plant. Cyberwarfare is the term assigned to online cyberwar between politically rival countries.

Although all industries are at risk of a cyberattack, some of the industries are the most breached. These industries include health care, food, retail, finance, and government. The health care industry is dominantly under phishing attacks during the COVID-19 pandemic to interrupt services and steal patient data. On the other hand, financial institutions are targeted to gain financial benefits, steal passwords, and face reputation loss among competitors.

2.3 The CIAAA Principle

Based on the motivation to launch cyberattacks, the ultimate objective of every organization is to ensure confidentiality (C), integrity (I), and availability (A) of data. These are the three principles that play a pivotal role in the security of every organization. However, the level of importance varies for every organization

Fig. 2.1 The CIA triad

depending upon its security goals and requirements. These principles are presented as three sides of a triangle, as shown in Fig. 2.1.

Confidentiality is the first principle in the CIA Triad. It refers to the protection of secret data, objects, or resources. The goal of confidentiality is to prevent or minimize unauthorized access to data. It ensures that only authorized users can access data and resources. In simple words, confidentiality ensures the protection of data from unauthorized access, use, or disclosure while in storage, process, or transit. Several cyberattacks focus on violating confidentiality. These attacks include eavesdropping, social engineering, port scanning, stealing passwords, and capturing network traffic.

Integrity is the second principle in the CIA Triad. It ensures the correctness and reliability of data. It prevents unauthorized users from modifying data. Proper implementation of integrity means authorized changes are allowed on sensitive data. Integrity loss may result from human errors such as an authorized user making an unintentional change to data. Integrity is prone to viruses, logic bombs, unauthorized access, malicious modification, backdoors, and coding errors.

Availability is the third principle in the CIA Triad. It refers to timely and uninterrupted access to authorized objects, data, or resources. Some of the pertinent threats to the availability of data include system failures, power loss, software errors, and environmental issues (natural calamities). In addition to that, sometimes, the accidental deletion of files, overutilizing a resource, or mislabeling a classified object can also result in the unavailability of data.

In addition to the traditional CIA Triad, two new principles are added to security. These two principles include accountability (A) and authenticity (A). The addition of two new principles to the CIA Triad makes it the CIAAA principle for new researchers as shown in Fig. 2.2. Accountability and authenticity are introduced below.

Accountability is referred to as the responsibility of a person to protect an asset, material, or key information. The person is held accountable for safeguarding the equipment in his custody. If a data breach, loss, or misuse of that equipment takes place, that person is held accountable for it. Accountability is an essential part of a cybersecurity plan. For example, let us assume that an organization has a policy that

Fig. 2.2 CIAAA principle

lists legitimate software or applications that the employees can install on their computers. If an employee installs software or applications not listed in the policy, the IT administrator is held accountable for not verifying the software or applications downloaded and installed on computer systems owned by the organization.

Authenticity is the validation of messages transmitted between a sender and receiver. It ensures that an authenticated sender originates from a message, the message is authenticated, and only an authentic receiver can receive the message. It helps to prevent an unauthorized person from sending or receiving a message. In technical terms, this principle prevents an impersonator from intercepting transmission. It requires users to establish their identities before getting involved in communication. Once the sender and receiver confirm their identities, they can access the system to communicate with each other. Authenticity is established by using usernames, passwords, smart cards, biometrics, emails, and tokens.

2.4 Cybersecurity Threats

Cybersecurity threat refers to anything that can harm the computer system, server, and computer network. Cybersecurity threats may occur or not, but they have the potential to cause severe damage to the organization's assets. They can lead to cybersecurity attacks. There are several types of cybersecurity threats that organizations can face. Some of the recent cyber threats that organizations have faced include malware, ransomware, phishing, stolen passwords, cyber fraud, and disruption of essential services. Figure 2.3 highlights some important cybersecurity threat statistics from 2018 to 2020.

These statistics indicate that cybercriminals interrupt indispensable services by sending phishing emails, executing malware on target computers, demanding ransom, stealing passwords and selling them, and indulging in cyber fraud activities. The list of malicious activities never ends.

According to a survey conducted by Yahoo Finance (Yahoo Finance 2021), phishing is the most common cyber threat that attackers take advantage of. However, due to cybersecurity awareness among employees, there is a significant



Fig. 2.3 Cybersecurity threats statistics 2018–2020

decline in phishing attacks. Although phishing attacks are declining, there is a 50% surge in unique cyber threats in 2020. Overall, 389 unique threats were observed in 2019, and the numbers increased to 600 in 2020. Further, the survey found that the financial industry is the most proactive and concerned with cyber threats.

From the perspective of financial institutions, threat hunting events are becoming quite common owing to a massive increase in cyber threats across banks and other financial institutions. Financial institutions have witnessed diverse types of common and unique cyber threats such as service-specific attacks and web attacks. They are also concerned with financially motivated nation-state activities. It is intriguing to mention that most cyber breaches are caused by human errors. Most of these breaches are financially motivated, while some are motivated by espionage. Moreover, there is a strong relationship between data breaches and stolen passwords because stolen passwords are the most common causes of data breaches.

All the cyber threats discussed above are external. There are some internal sources of cyber threats. For example, a disgruntled employee who is dissatisfied with the employer may steal, delete, or modify some critical data to cause intentional harm to the organization. There are some serious attempts in which an employee exploits a vulnerability in the installed application or software to perform illegitimate and unauthorized activities that may spoil the reputation of the organization.

2.5 Cybersecurity Attacks

A cybersecurity attack or cyberattack is the intended action of an attacker to cause harm to the computer system, server, and computer network. It is a deliberate action that involves a motive and plans to attack the target. A cyberattack has more chances of success as compared to a cyber threat because it is intentional and well planned.

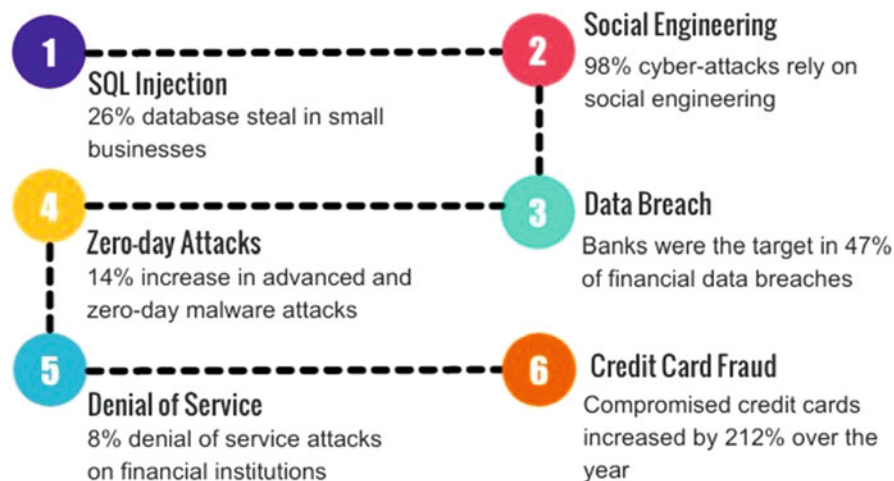


Fig. 2.4 Cyberattack statistics of 2020

Some common examples of cyberattacks include denial of service, distributed denial of service, SQL injection, social engineering, and zero-day attacks. All these attacks will be explained in detail in the coming chapters.

Cyberattacks can be politically or financially motivated. The main purpose of launching cyberattacks is to steal sensitive information, interrupt essential business services, damage reputation, and cause financial losses. Depending upon the motive of the cyberattack, attackers prepare a plan and execute it in a perfect manner to achieve their objectives.

Figure 2.4 highlights major cyberattack statistics of the year 2020 published by Purplesec (Cyber Security Statistics 2020). Credit card fraud cases are on top of cyberattacks. It is followed by data breach as a quite common cyberattack in the financial sector. Financial institutions have witnessed 85 denials of service attacks in the past year. Attackers also steal data from databases by utilizing SQL injection attacks. Further, social engineering is an important key to gathering information about the target person, computer, and company. Cyberattacks not only target computer systems, but smartphone devices have also fallen as an easy prey for them.

Apart from the financial sector, cyberattacks are prevalent in every other industry such as health care, education, federal and local government, and transportation. After the financial sector, health care is the biggest target for cyberattacks. Attackers are interested in medical records, social security numbers, and other personal data. Since the inception of the COVID-19 pandemic, there is a 238% rise in cyberattacks on banks (134 Cybersecurity Statistics and Trends for 2021 2021). Out of the increased cyberattacks, 27% targeted banks and the health care sector only. All these statistics make it paramount to analyze the current cybersecurity situation and understand its importance.

2.6 Cybersecurity Analysis

Based on the cybersecurity threats and attacks reported in recent years, cybersecurity analysis ensures whether the organization is protected against cyberattacks or not. With the use of technology, huge volumes and a variety of data are gathered. Processing big data is transforming the way companies do business. It helps to analyze historical cyberattack data to predict future cyberattacks. Nevertheless, managing big data also brings new challenges. So, how does cybersecurity analysis help in managing such a huge amount of cyberattack data?

Cybersecurity analysis does the groundwork to prepare organizations for cybersecurity challenges, forecast cybersecurity threats and vulnerabilities, perform security analytics, provide endpoint security, and protect data. Figure 2.5 provides an overview of different activities performed during cybersecurity analysis.

- **Cybersecurity challenges:** Cyberattacks have grown extremely fast in the past. Keeping in mind the rapid rate at which common and advanced cyberattacks have targeted humankind, several cybersecurity challenges are addressed by cybersecurity analysis. The most important cybersecurity challenges can be classified into three categories: disruption, distortion, and deterioration. Disruption refers to the interruption of services and flow of information. It covers denial of service, distributed denial of service, and ransomware attacks. Distortion means playing with the integrity of information. It includes data breach, modification, and deletion. Deterioration refers to lowering the ability to control information. It consists of unauthorized access to information.
- **Forecast threats and vulnerabilities:** Cybersecurity analysis examines existing threats and vulnerabilities to predict the future trends in threats and

Fig. 2.5 Activities performed during cybersecurity analysis



vulnerabilities. Threats are becoming more targeted and sophisticated. Therefore, cybersecurity analysis understands the threat landscape and forecasts threat detection to correlate threats with vulnerabilities. Although it is impossible to predict future threats as the nature of threats is always changing but cybersecurity analysis attempts to do that.

- **Security analytics:** Security analytics focuses on the analysis of data to produce proactive security measures. For example, network traffic can be monitored to identify any suspicious activity and respond appropriately to protect the network.
- **Endpoint security:** Endpoint security is provided by installing security devices such as firewalls, intrusion detection and prevention systems, and antivirus solutions. All these solutions detect malicious activities on the network and try to prevent them. For example, antivirus solutions detect a malicious file on the computer system and delete it to clean the computer system.
- **Protect data:** Cybersecurity analysis provides protection to data by encrypting data at rest and in transit. It also takes a backup of data so that an updated copy of data is available even in case of an emergency.

2.7 Why Cybersecurity Matters

Cybersecurity protects people and organizations from the evil acts of attackers. It covers the organization's critical data, resources, assets, and reputation. The purpose of securing an organization is to prevent data and financial losses. Cybersecurity incidents are politically or financially motivated. Cybersecurity incidents target the financial sector and all the critical sectors that contribute to the country's economy. For example, health care, transportation, sports, government, and trade are equally essential to building a nation. In some cases, malicious cross-border activities also tend to shut down the economy of the target country.

Beyond threatening the organization's data, cybersecurity incidents can cause harm to the functioning of communication channels, energy, and critical infrastructure. Cyberattacks on the power grid, energy sector, and health care databases are quite common. Attackers are looking for sensitive data such as medical records that contain social security numbers, credit card details, and other personal data. These data are misused to launch other cyberattacks. In some cases, cybercriminals sold the stolen data on the dark web. This data was later used for sending online advertisements.

Information theft or data leakage is the most expensive and fastest-growing cybercrime. In one of the famous data breaches, the customer data of famous restaurant chains were stolen and sold online. Another attacker group purchased that data and misused it to launch cyberattacks a few years later. Such incidents govern the importance of securing organizational and personal data.

Cyberattacks such as ransomware and phishing are so common that every data breach takes advantage of these tactics. Cybercriminals used ransomware attacks (WannaCry ransomware) in 2017 to encrypt confidential data of more than 200,000 computers across 150 countries. They demanded ransom to release the data. The

total financial losses because of the WannaCry ransomware attack were estimated to be billions of dollars.

Cybersecurity encompasses everything that pertains to the security of sensitive data, personally identifiable information, health care credentials, intellectual property, personal data, and government information systems. Cybersecurity risk is governed by global connectivity. There are no boundaries to cyberattacks. The modern-day cybersecurity solutions not only include firewalls and antivirus solutions but advanced threat hunting infrastructures that can make use of detection, analysis, and correlation functions to mitigate cyber threats.

2.8 Data Science and Important Data Breachers

Data science is an emerging field of cybersecurity. It helps data scientists to ask rigorous questions, formulate theoretical structures, analyze big data, and provide a deep insight into analyzed data. With the plethora of messy data getting accumulated every day, big companies thought of extracting useful information from that data and analyzing the extracted information to dig deeper into making mappings for current and future patterns. For example, Facebook asks every user about his location to make it easier for his friends to connect to him. This data can be used to analyze global migration patterns. Similarly, users can use social media data such as Facebook friend connections to determine the cultural diversity, interests, and choices of a user.

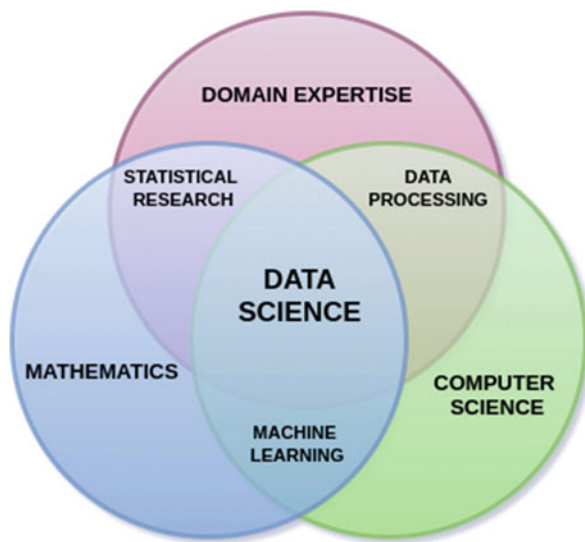
Another simple example of data science is when YouTube suggests videos to a user based on the previously watched content on the channel. It stores every user's browsing history and performs data science operations to identify similar content or videos that the user may be interested in. All this is possible because of data science.

Although there is no definition of data science, it is most famously represented by a Venn diagram shown in Fig. 2.6. Data science is an interdisciplinary approach that collaborates with domain expertise, mathematics, and computer science. Domain expertise defines problem space, mathematics provides problem-solving theoretical structure, and computer science opens the data manipulation environment for data science.

Domain Expertise focuses on specific business environments such as finance, transportation, or healthcare. Domain experts possess sound knowledge of the business domain they belong to. The primary objective of applying data science operations in the business domain is to improve sales and increase profits. The expected outcome of applying data science to the business domain is expected to be quantified and measurable. Domain experts focus on the following exemplary questions to do so:

- Can the productivity of a specific department be improved by using heuristic data?
- Can competitiveness be improved by using product attributes?

Fig. 2.6 Venn diagram presenting data science as an interdisciplinary approach



Source: Palmer, Shelly. *Data Science for the C-Suite*. New York: Digital Living Press, 2015. Print.

More specific questions lead to actionable results.

Mathematics provides problem-solving skills for data science operations. Mathematicians use statistical modeling, probability theory, analytics, predictions, and pattern recognition techniques to solve complex problems. Data science is meant to apply to big datasets to perform complex mathematical computations. For example, in cybersecurity, data scientists use big datasets containing malicious network traffic and apply data science operations to identify and analyze attack patterns to predict the probability of future attacks.

Computer Science provides a data manipulation environment to perform data science operations. Continuing the cybersecurity example, big datasets contain large volumes, variety, and velocity of data that cannot be handled manually. Therefore, there comes the need for computer programs or models that can automatically analyze such large datasets to yield desired predictions. Data scientists use machine learning models to automate the data analysis process. Machine learning consists of supervised and unsupervised models that can help in the classification and prediction of data, respectively.

2.8.1 Important Data Breaches

Data breach, also called data theft, is the disclosure of sensitive private/confidential information to untrusted sources. Data breach is alternatively called data leak, information leakage, and data spill. Data breaches involving millions, or billions of records are quite common across the globe. The twenty-first century has witnessed

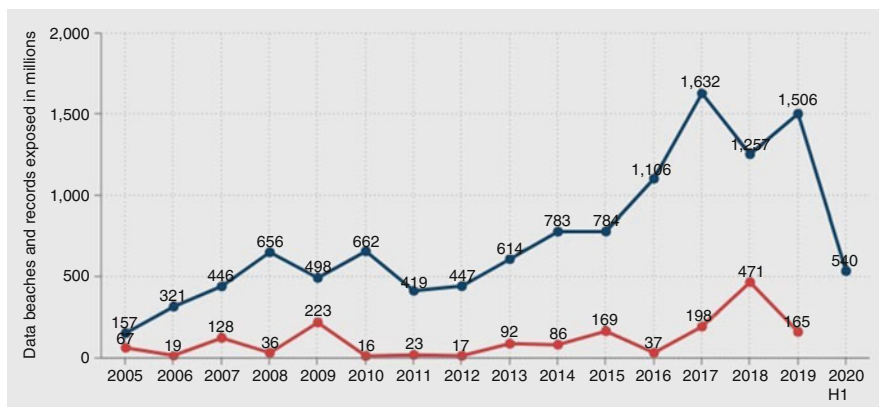


Fig. 2.7 Annual data breaches and records exposed in the USA (Statista 2020)

myriads of important data breaches that stole customers' credit card data, bank account details, and personally identifiable information (PII). Common types of data breaches include ransomware, phishing, and DoS attack.

Figure 2.7 demonstrates the annual data breaches (blue curve) and records (red curve) exposed due to those breaches in millions from 2005 to the first half of 2020. The data belongs to breaches in the USA only. The trend of data breaches has increased from 2005 to 2017. There is a sudden decline in this trend in 2018 and it jumped up again in 2019. Analyzing the records that were exposed to untrusted sources during these data breaches, it is evident that the highest number of records were exposed in 2018 even though the number of breaches in that year were comparatively less. These facts are alarming and need instant attention.

Some of the most significant data breaches of this century include big names such as Adobe, eBay, LinkedIn, Marriott International, and Yahoo. The biggest of these was related to Marriott International that spanned between 2014 and 2018. It stole the credit card data of around 100 million customers. In addition, passport numbers, guest numbers, travel information, and other personal information from 500 million customers were stolen. The breach began in 2014 in Starwood hotel brands which Marriott International acquired in 2016. It came to light in September 2018 and was officially announced in November 2018.

In another important incident, LinkedIn became the victim of social engineering attacks in 2012 and 2016. Since LinkedIn is one of the largest social networking sites for professionals, it has become an attraction for attackers. In 2012, LinkedIn announced that 6.5 million passwords were stolen by attackers. These passwords were posted on a Russian hacker forum. In 2016, the same hacker group sold the stolen passwords of around 165 million LinkedIn users. In order to reduce the impact of this breach, LinkedIn urged its users to change their passwords immediately.

In yet another important data breach, Yahoo disclosed in 2016 that it had witnessed the biggest data breach in history in 2014. The state-owned actors stole real names, email addresses, passwords, phone numbers, and the date of birth of

500 million Yahoo users. These numbers raise concern over the importance of protecting sensitive user information.

Figure 2.8 presents the world's biggest data breaches reported between 2014 and 2018. Bubble size represents the number of records exposed. Bigger bubbles mean more records are exposed, while smaller bubbles correspond to fewer records exposed. These data breaches cover communication and social networking sites (Facebook, Yahoo, Gmail, Slack, Snapchat, Instagram, Twitter), the aviation industry (British Airways, Japan Airlines), the financial sector (NASDAQ, JP Morgan Chase, European Central Bank), internet service providers (Bell), government databases (Korea, USA, Turkey, Philippines, India), restaurants (Domino's Pizza of France, Wendy's), health care (Community Health Systems), web browsers (Mozilla), stores (Home Depot, Staples), media (River City Media, Viacom), and transportation (Uber, New York Taxis). Simply put, all the important business sectors have witnessed and reported major data breaches in the last 5 years.

Most of the data breach categories reported in Fig. 2.8 include hacked, poor security, lost/stolen media, insider job, and accidentally published reports. Hacking is the dominating category that has resulted in these data breaches. The information used to plot these data breaches is publicly available. Although the excel sheet at that source contains data breaches between 2005 and 2018 but only recent data breaches are plotted here. Detailed information on worldwide data breaches is available at bit.ly/bigdatabreaches.

2.9 The NSA Triad for Security Assessment

The National Security Agency (NSA) provides a detailed and systematic method of assessing, evaluating, and testing security vulnerabilities from an organizational perspective. The NSA triad focuses on three main aspects of assessment, evaluation, and testing of security vulnerabilities by following Information Security (INFOSEC) Assessment Methodology (IAM) (Johnson 2004). IAM was established by experienced NSA and INFOSEC assessors in the USA in 1997. However, it became known in 2001.

IAM serves the purpose of assessing the security vulnerabilities of an organization and providing detailed information on what to look for in a security assessment. It also raises security awareness among organizations. Without going into more details of NSA IAM, this section lays stress on three main activities performed by this triad: assessment, evaluation, and testing (Miles et al. 2004).

Before starting the security assessment process, it is imperative to understand what needs assessment. For example, an organization has several critical resources that may be attacked. Does the organization want all of them assessed? The answer to this question is a three-level top-down approach that starts with assessment at the top, followed by evaluation in the middle, and attack and penetration testing at the bottom. Since it is a top-down approach, every level adds more details and concrete information to the security assessment process.

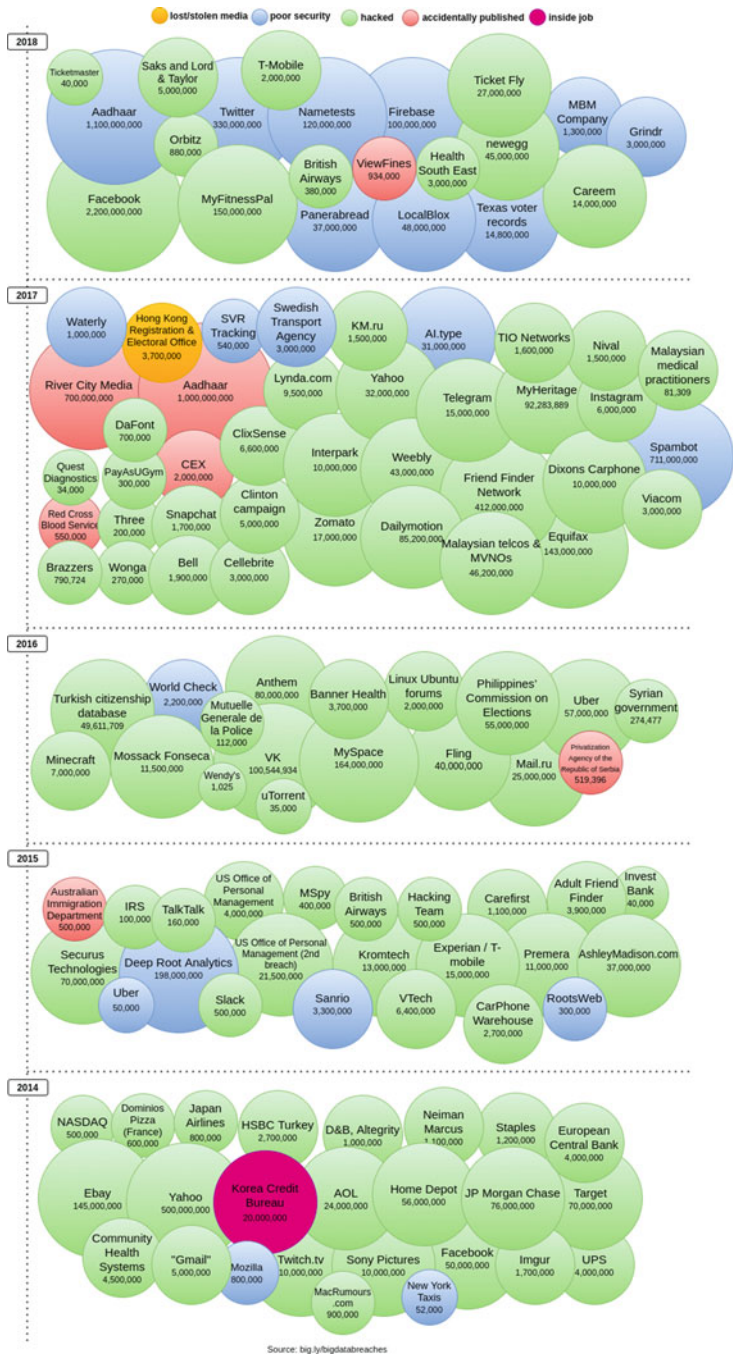


Fig. 2.8 World's biggest data breaches between 2014 and 2018 (Information is Beautiful: Data Breaches (public) 2018)

Table 2.1 NSA's top-down approach for security assessment

Assessment (Level I)	Evaluation (Level II)	Attack and penetration testing (Level III)
Nontechnical	Technical	Highly technical
Provides a high-level view	Looks for vulnerabilities.	Exploits vulnerabilities
Theoretical	Hands-on scanning	Practical attacks and penetration
No use of tools	Diagnostic tools	Penetration tools
Intermediate expertise to gather information	Intermediate/expert knowledge	Requires special expertise (red team)
Produces concrete information about organization structure, resources, and information systems	Produces a detailed list of vulnerabilities in hardware, software, and network	Produces hands-on results on how adversaries can attack the network

- **Assessment:** It lies at the organizational level and focuses on addressing non-technical questions. An assessor analyzes security policies, procedures, standards, architecture, and organizational structures in place. This is a theoretical step and does not involve any practical sessions. At the end of this step, the assessor can understand critical information, systems, and structure of organization. This level provides a high-level corporate view. The meticulous details gathered at this level help draft an evaluation strategy at the next level.
- **Evaluation:** This is the second level of the top-down approach. It is a technical round that primarily focuses on identifying security vulnerabilities in the critical systems identified in the assessment. It also understands how the identified security vulnerabilities can be exploited by the attacker. This is a hands-on process in which diagnostic tools are used to scan the computer systems in the organization. These tools provide a comprehensive list of vulnerabilities in hardware, software, and network. It further provides information on how these vulnerabilities can be fixed to escape exploitation. At the end of this step, the assessment team has extensive information that can lead to future evaluations.
- **Attack and penetration testing (Red teaming):** This is the bottom level of the approach and is highly technical. It requires technical expertise to attack and test the organizational network. This level is also called attack and penetration testing or red teaming. Red teaming is a process in which the team members imitate attackers and launch adversarial attacks on organizations. The purpose of launching these attacks is to understand how easy or difficult it would be for attackers to identify flaws in the organizational network and exploit vulnerabilities. The activity performed by the red team is called penetration testing.

Table 2.1 summarizes the top-down approach and provides a comparison of activities performed at each level.

2.10 Data-Centric Security Management

Data breaches have become more frequent and have created a burden on financial sources to protect data. As the volume of data grows, traditional network-based security models become incapable of detecting data breaches. The reason for the failure of traditional network security models is that they are focused on the location of data. That means these models concentrate on where the data is located. Data-centric security management is different from traditional network security models because it protects from data breaches irrespective of where the data is located.

Data-centric security management no longer considers borders, perimeters, and endpoint security of network data. It emphasizes data-centric characteristics that apply protection to data itself. As soon as new data is created or existing data is modified on a computer system and server, the data-centric security management system scans the computer system to verify whether the data contains sensitive information. A data-centric security management system protects confidentiality, integrity, and availability of information, assets, and resources from threats and vulnerabilities.

2.10.1 Data-Centric Security Cycle

Data-centric security is a five-step cyclic model that includes data protection, transfer, control, access, and measurement as shown in Fig. 2.9 (Nicho and Advani 2012).

- **Protect** data from unauthorized use irrespective of where it is stored. Data protection is achieved by using encryption and passwords. Only encrypted data

Fig. 2.9 Data-centric security cycle model



can be transmitted between a sender and receiver. Encrypting data ensures that data cannot be stolen by adversaries. A data-centric solution provides persistent protection of data at rest, in transit, and in use.

- **Transfer** means delivering and sharing sensitive information stored in files. Information can be shared within or outside the network.
- **Control** access to sensitive information even after it is shared and transmitted. This ensures that access rights are properly applied to sensitive information files. Access rights are used to control who has access to files. Only the authorized person can make changes to the sensitive information. Three types of access rights are assigned to every user: administrator, user, and guest. This concept puts data control in the hands of data administrators (data owners) and provides a clear distinction between activities performed by administrators, users, and guests.
- **Access** permissions on sensitive information can be revoked any time after transmission. This is a continuous process that is completed on a regular basis.
- **Measure** the activities performed by users and perform regular audits to verify that the required control measures are in place.

2.10.2 Characteristics of Data-Centric Security Management

Data-centric security management is designed with the following characteristics to protect data theft (PKWARE 2020):

- **Centralized control:** Data-centric approach follows a centralized control for data protection. The centralized control keeps track of any changes to data in the database records. As soon as sensitive information is identified, data protection is applied to it. Sensitive information is encrypted and passwords to protect data are stored safely and shared with recipients.
- **Automation:** With the increasing volume of data, it becomes unmanageable to apply a centralized data protection approach in an effective manner. Automated data protection is the key to encrypting data and preventing data theft.
- **Adaptable:** Every organization has a distinct size and type of data and data protection policies. Further, these characteristics vary within an organization as well. A good data-centric security management system must be adaptable to cater for all these requirements.
- **Gapless protection:** Data-centric security considers gaps in data storage and transmission. Data may be stored and transmitted without encryption. However, a data-centric approach makes sure that such gaps are identified and taken care of.

2.10.3 Problems with Data-Centric Security Management

Despite managing four main characteristics of data-centric security, there are the following problems with the system (Armoni 2002):

- **Inefficient distributed systems:** Data-centric security management is a centralized approach, but it becomes inefficient in a distributed (non-centralized) system. In a distributed system, there are several protection points that increase the complexity of the system. Furthermore, the process becomes cumbersome for manually updated systems.
- **Human behavior:** Data-centric uses encryption and passwords to protect data. However, it is human behavior to use the same password over again. Reusing the same password creates another problem for data-centric systems.

2.11 Chapter Summary

This chapter introduces the basic principles of cybersecurity. After understanding cybersecurity and the three principles of protecting data, the motivation to carry out cyberattacks is put forward. The CIA triad is an inseparable part of cybersecurity that ensures confidentiality, integrity, and availability of data. It is extended by adding two more principles of accountability and authenticity. Several data breaches reported in the last couple of years are listed. Analysis of data breach information reveals that data breaches are quite common, and they result in exposure to millions of data records. Further, data breaches affect financial institutions (banks, stock market, and capitalists) and FinTech startups (payment systems, lending, wealth management, crowdfunding, insurance companies, and stock markets) in the FinTech ecosystem.

The top-down approach to assess the security of an organization using the NSA IAM process is introduced. The process obtains meticulous information about the organization at the first level, gathers more critical information related to vulnerabilities in organization and how they can be exploited by scanning the network, and then a red team performs adversarial attacks to understand how the attacker can exploit the vulnerabilities in the organization network. Finally, various aspects of securing information are brought forward at the end of the chapter. After understanding all the fundamental concepts, the following questions are addressed in this chapter:

- What are the motivations to launch a cybersecurity attack?
- What are the essential elements of the CIAAA principle?
- What is the importance of cybersecurity?
- What are important data breaches that how do they impact the financial sector?
- How can the security of an organization be assessed?
- How can data-centric security be managed?

References

- 134 Cybersecurity Statistics and Trends for 2021. (2021). <https://www.varonis.com/blog/cybersecurity-statistics/>.

- Armoni, A. (2002). Data security management in distributed computer systems. *Informing Science*, 5(1), 19–27.
- Boer, M., & Vazquez, J. (2017). Cyber security & financial stability: How cyber-attacks could materially impact the global financial system, *Institute of International Finance*, pp. 1–9.
- Cyber Security Statistics. (2020). <https://purplesec.us/resources/cyber-security-statistics/>.
- Information is Beautiful: Data Breaches (public). (2018). bit.ly/bigdatabreaches.
- Johnson, B. C. (2004). *National Security Agency (NSA) INFOSEC Assessment Methodology (IAM)* (pp. 1–6). <https://systemexperts.com/pdf/NSAIAM.pdf>
- Miles, G., Rogers, R., Fuller, E., Hoagberg, M. P., & Dykstra, T. (2004). *Security assessment: Case studies for implementing NSA IAM*. Rockland: Syngress.
- Nicho, M., & Advani, A. (2012). A data centric Security cycle model for data loss prevention of custodial data and company intellectual property. *SECURWARE 2012: The sixth international conference on emerging security information, systems and technologies* (pp. 134–141).
- PKWARE. (2020). *A blueprint for data-centric security, whitepaper*. PKWARE. <https://www.pkware.com/data-centric-security-whitepaper>
- Statista. (2020). *Annual number of data breaches and exposed records in the United States from 2005 to 1st half 2020*, Statista. <https://www.statista.com/statistics/273550/data-breaches-recorded-in-the-united-states-by-number-of-breaches-and-records-exposed/>.
- Vaidya, T. (2015). *2001–2013: Survey and analysis of major cyberattacks* (pp. 1–25). <https://arxiv.org/abs/1507.06673>.
- Yahoo Finance. (2021). *Over 50% increase of unique cyber threats in the wild in 2020, cymulate's continuous security testing report reveals*. New York: Yahoo Finance. <https://finance.yahoo.com/news/over-50-increase-unique-cyber-130000675.html>.